RFC-003 - CPF, JWT RS256 e autorização

Status: justificativa técnica da implementação existente, aberta à revisão da equipe.

Solução

A Lambda customer-auth valida o CPF e o status do cliente no RDS antes de emitir JWT. A Lambda jwt-authorizer valida assinatura/issuer/expiração para as rotas protegidas do HTTP API. A aplicação aplica RBAC e propriedade dos recursos. As funções são distintas: emitir uma identidade e aceitar uma identidade são responsabilidades diferentes.

Alternativas consideradas

JWT apenas na API simplifica o caminho interno, mas não demonstra o Authorizer no Gateway. Tokens opacos com sessão central permitem revogação mais imediata, mas adicionam consulta de sessão ao caminho de autenticação. Um provedor de identidade gerenciado pode melhorar segurança de uso comercial; não substitui automaticamente a função CPF exigida no desafio.

Consequências e limites

RS256 permite validar com chave pública sem distribuir a privada ao Authorizer. As chaves privadas continuam necessárias aos emissores e devem permanecer em secrets. Cache zero no Authorizer simplifica os testes de autorização e evita cache de uma decisão anterior. A emissão via CPF sem fator adicional é uma escolha acadêmica, insuficiente como única prova forte de identidade em um produto comercial.

Cliente inativo não recebe novo token. Um token já emitido pode continuar válido até expirar; não se afirma revogação imediata. CPF/JWT/senhas não devem ser exibidos no vídeo/logs.

Verificação

Matriz real em homolog: login conhecido e acesso CUSTOMER 200; documento sem cadastro e ausência de token 401; Bearer malformado, token alterado e rota operacional CUSTOMER 403. O status HTTP de negócio deve ser distinguido de falha 5xx de integração.